Société TALBAGO

POLITIQUE DE GESTION DES PROJETS CYBERSÉCURITÉ

Cyber Security Project Management

Cadrage de la sécurité du projet Cloud public

Projet	Politique de Gestion des Projets Cybersécurité
Client	TALBAGO
Prestataire	CYBERSÉCURITÉ FRANCE
Référence	TALBAGO-DSI-SEC-CLOUD-2026-01
Version	1.0
Date	15/03/2026
Classification	Confidentiel

Validé par :
RSSI – TALBAGO

Table des matières

1. Contexte Stratégique et Impératifs de la Transformation Numérique ... 3
2. Pression Réglementaire et Enjeux de Conformité ... 3
2.1. Le Règlement Général sur la Protection des Données (RGPD) ... 3
2.2. La Directive Européenne NIS2 ... 3
2.3. Le Règlement DORA et la Résilience Opérationnelle ... 4
3. Fondements Normatifs : ISO/IEC 27001 — Annexe A 5.8 ... 4
4. Gouvernance et Instances de Pilotage de la Sécurité ... 4
4.1. Le Cloud Center of Excellence (CCoE) ... 4
4.2. Matrice des Responsabilités Projet (RACI) ... 5
5. Périmètre et Champ d'Application ... 5
6. Le Cycle de Vie de Développement Sécurisé (SecSDLC) ... 5
6.1. Phase d'Initialisation et d'Évaluation des Risques ... 5
6.2. Phase de Conception — Security by Design ... 6
6.3. Phase de Développement et d'Implémentation ... 6
6.4. Phase de Recette et de Validation ... 7
6.5. Homologation de Sécurité et Déploiement ... 7
6.6. Maintien en Condition de Sécurité (MCS) et Fin de Vie ... 7
7. Intégration Transverse : Gestion des Changements et Fournisseurs ... 7
7.1. Articulation avec la Politique de Gestion des Changements ... 7
7.2. Maîtrise des Risques liés aux Tiers et Fournisseurs Cloud ... 7
8. Référentiels et Normes Applicables ... 8
9. Indicateurs de Pilotage (KPIs) et Amélioration Continue ... 8
10. Procédure d'Évolution et de Révision ... 9
11. Sanctions et Non-Conformité ... 9
PRO-1. Phase d'Initialisation — Qualification Sécurité du Projet ... 10
PRO-2. Phase de Conception — Architecture Sécurisée ... 11
PRO-3. Phase de Développement — DevSecOps et Infrastructure as Code ... 12
PRO-4. Phase de Recette — Validation Sécurité ... 14
PRO-5. Déploiement en Production et Activation des Contrôles ... 15
PRO-6. Maintien en Condition de Sécurité (MCS) ... 16
PRO-7. Fin de Vie — Démantèlement Sécurisé ... 17
PRO-8. Gestion des Dérogations ... 18
PRO-9. Procédure d'Escalade et de Gestion des Incidents Sécurité ... 18
PRO-10. Formulaires et Documents de Référence ... 19

PARTIE I — POLITIQUE DE GESTION DES PROJETS CYBERSÉCURITÉ

1. Contexte Stratégique et Impératifs de la Transformation Numérique

La société TALBAGO traverse une phase de transformation numérique critique, motivée par le développement international et le déploiement de solutions logicielles en mode Web à destination de ses clients. Historiquement spécialisée dans la conception de systèmes de tri intelligents intégrant des capteurs de pointe, des algorithmes d'intelligence artificielle et l'analyse continue des flux de matériaux pour l'économie circulaire, l'entreprise a jusqu'à présent opéré ses infrastructures de traitement au sein de centres de données (datacenters) hébergés en propre.

La décision stratégique de déployer une partie substantielle de ces applications, des environnements de développement et des données vers le Cloud public introduit un changement de paradigme fondamental dans la gestion de l'information et des ressources technologiques. Le modèle de sécurité traditionnel, fondé sur la protection périmétrique des infrastructures physiques, s'avère caduc face aux architectures distribuées, élastiques et accessibles depuis Internet.

Le recours au Cloud public implique l'acceptation d'un modèle de responsabilité partagée. Dans ce modèle, le fournisseur de services Cloud (CSP) garantit la résilience et la sécurité physique de l'infrastructure sous-jacente, tandis que TALBAGO demeure l'unique responsable de la sécurité de ses données, de la configuration de ses environnements virtuels, de la gestion des identités et des accès, ainsi que de la sécurisation du code applicatif déployé.

La présente Politique de Gestion des Projets Cybersécurité est donc instituée pour formaliser l'intégration systémique et itérative des exigences de sécurité au cœur de chaque initiative technologique. Ce document définit le cadre méthodologique, les obligations procédurales, les jalons de validation et les responsabilités incombant à l'ensemble des parties prenantes impliquées dans la conception, le développement, l'intégration et le déploiement de projets informatiques au sein de TALBAGO.

2. Pression Réglementaire et Enjeux de Conformité

L'élaboration de cette politique s'inscrit dans un paysage réglementaire européen et national particulièrement exigeant, qui impose à TALBAGO des obligations de résultats quant à la protection de son patrimoine informationnel et des données qui lui sont confiées.

2.1. Le Règlement Général sur la Protection des Données (RGPD)

Les solutions d'intelligence artificielle et de contrôle qualité développées par TALBAGO, ainsi que la nouvelle plateforme Web destinée aux clients, sont susceptibles de traiter des données à caractère personnel. Le RGPD impose les principes de "Privacy by Design" et de "Privacy by Default". La gestion de projet doit documenter formellement ces principes à travers la réalisation d'Analyses d'Impact sur la Protection des Données (AIPD) lors des phases d'initialisation.

2.2. La Directive Européenne NIS2

En tant qu'acteur industriel potentiellement qualifié d'entité essentielle ou importante, TALBAGO est soumise à des exigences strictes en matière de gestion des risques liés à la sécurité des réseaux et des systèmes d'information. La directive NIS2 étend explicitement ces exigences à la sécurité de la chaîne

d'approvisionnement (Supply Chain Security) et aux relations avec les prestataires de services numériques, incluant les fournisseurs Cloud.

2.3. Le Règlement DORA et la Résilience Opérationnelle

Les principes édictés par le règlement DORA (Digital Operational Resilience Act) concernant la résilience opérationnelle numérique influencent fortement les bonnes pratiques industrielles et sont explicitement mentionnés dans les enjeux de TALBAGO. Tout projet informatique doit intégrer la conception de Plans de Continuité d'Activité (PCA) et de Plans de Reprise d'Activité (PRA), avec la définition formelle d'objectifs RPO (Recovery Point Objective) et RTO (Recovery Time Objective).

3. Fondements Normatifs : ISO/IEC 27001 — Annexe A 5.8

La présente politique est bâtie sur le socle des meilleures pratiques internationales, en particulier la norme ISO/IEC 27001:2022. Cette norme impose un système de management de la sécurité de l'information (SMSI) fondé sur l'appréciation continue des risques. L'intégration de la sécurité dans la gestion de projet est une exigence explicite et non négociable, détaillée dans le contrôle de l'Annexe A 5.8 (Information security in project management).

L'objectif fondamental du contrôle 5.8 est de garantir que la sécurité de l'information est intégrée dans toutes les méthodologies de gestion de projet de l'organisation, quelle que soit leur nature. La norme prohibe catégoriquement l'approche où la sécurité est traitée comme une réflexion après coup. Au contraire, elle exige l'application systémique des concepts de "Security by Design".

Exigences clés du contrôle ISO 27001 A.5.8

- Les risques liés à la sécurité doivent être évalués et traités de manière précoce et périodique tout au long du cycle de vie du projet.
- Les exigences de sécurité doivent être définies explicitement dans les cahiers des charges dès la phase d'initialisation.
- Des rôles de sécurité spécifiques doivent être attribués au sein de chaque équipe de projet.
- Une ségrégation étanche entre les environnements de développement, de test et de production est obligatoire.
- Les données de production réelles ne peuvent être utilisées en environnement de test qu'après anonymisation certifiée (A.8.33).

4. Gouvernance et Instances de Pilotage de la Sécurité

Pour s'assurer que les directives théoriques de la norme ISO 27001 se traduisent par des actions opérationnelles vérifiables, TALBAGO s'appuie sur une structure de gouvernance solide. La décentralisation inhérente aux méthodologies agiles et à l'exploitation du Cloud exige une centralisation de la doctrine de sécurité.

4.1. Le Cloud Center of Excellence (CCoE)

Le CCoE est une entité dotée d'une autorité formelle et contraignante sur l'ensemble des standards de sécurité Cloud de l'entreprise. Il a pour mandat de définir, maintenir et faire appliquer le socle doctrinal de sécurité, en s'appuyant sur les référentiels reconnus : Cloud Controls Matrix (CCM) de la CSA, CIS Benchmarks et recommandations ANSSI.

Dans le cadre de la gestion de projet, le CCoE agit comme l'instance de validation suprême lors des phases critiques. Il évalue les dérogations potentielles au Plan d'Assurance Sécurité (PAS) et prononce les avis techniques de sécurité préalables à toute mise en production.

4.2. Matrice des Responsabilités Projet (RACI)

Rôle Projet	Responsabilités Spécifiques en Cybersécurité
Direction des Systèmes d'Information (DSI)	Maîtrise d'ouvrage et pouvoir adjudicateur. Valide les budgets de sécurité, assume formellement les risques résiduels lors de l'homologation.
RSSI — Responsable de la Sécurité des SI	Propriétaire de la stratégie de sécurité Cloud. Audite les projets, valide le PAS, apporte son expertise lors des analyses de risques.
Chef de Projet (Project Manager)	Interlocuteur principal de pilotage. Responsable de l'intégration des exigences de sécurité dans le cycle de vie (ISO 27001 A.5.8) et du maintien du registre des risques.
Architecte Cloud & Sécurité	Conçoit l'architecture en respectant les principes Secure by Design et Zero Trust. Définit la segmentation réseau, les mécanismes de chiffrement et les politiques IAM.
Équipes de Développement (DevOps)	Appliquent les standards de codage sécurisé, implémentent l'IaC, traitent et rémédie aux vulnérabilités identifiées par les outils SAST/SCA dans les pipelines CI/CD.
Cloud Center of Excellence (CCoE)	Instance de validation suprême lors des phases critiques. Évalue les dérogations au PAS, prononce les avis techniques avant mise en production, maintient les standards Cloud.

5. Périmètre et Champ d'Application

La présente politique s'applique à l'ensemble des projets informatiques de TALBAGO impliquant :

- Le déploiement d'applications et de données vers des environnements Cloud publics (IaaS, PaaS, SaaS).
- Le développement ou la mise à jour d'applications exposées à Internet ou hébergées dans le Cloud.
- L'intégration de services tiers ou de composants open-source dans le système d'information.
- Toute modification substantielle des infrastructures ou des architectures techniques existantes.

Les obligations définies dans ce document s'imposent à l'ensemble des équipes internes (DSI, développement, architecture, sécurité) ainsi qu'aux prestataires externes intervenant sur les systèmes d'information de TALBAGO.

6. Le Cycle de Vie de Développement Sécurisé (SecSDLC)

La concrétisation de la présente politique impose l'adoption d'un cycle de développement logiciel sécurisé (Secure Software Development Life Cycle — SecSDLC) pour tout projet informatique au sein de TALBAGO. L'approche traditionnelle consistant à réaliser un test d'intrusion en fin de cycle est formellement bannie au profit d'une démarche "Shift-Left", visant à anticiper et traiter les vulnérabilités le plus tôt possible.

6.1. Phase d'Initialisation et d'Évaluation des Risques

Dès l'expression des besoins métiers, le chef de projet doit solliciter l'accompagnement des équipes de sécurité pour qualifier la sensibilité du projet. Cette qualification s'opère par l'identification, la classification et la valorisation des actifs informationnels et techniques concernés.

Une analyse de risques formelle doit être menée selon la méthode EBIOS Risk Manager, reconnue et soutenue par l'ANSSI. Les résultats de cette analyse permettent de définir les exigences de sécurité couvrant les dimensions DICT (Disponibilité, Intégrité, Confidentialité, Traçabilité).

Livrables obligatoires — Phase d'Initialisation

• Registre des risques du projet (document vivant mis à jour tout au long du cycle de vie).
• Classification des actifs et des données (public, interne, confidentiel, données personnelles RGPD).
• Analyse d'Impact sur la Protection des Données (AIPD) si des données personnelles sont traitées.
• Validation par le RSSI avant démarrage de la phase de conception.

6.2. Phase de Conception — Security by Design

L'architecture du système doit être intrinsèquement conçue pour prévenir, détecter et limiter l'impact des attaques. Pour les environnements Cloud, l'architecture doit intégrer dès sa genèse le concept de Zero Trust : aucune entité ne doit bénéficier d'une confiance par défaut. Chaque demande d'accès doit être authentifiée, autorisée et chiffrée de bout en bout.

Exigences de conception obligatoires :

- IAM : MFA obligatoire sur tous les vecteurs d'accès (console, CLI, API), SSO fédéré requis, principe de moindre privilège, accès Just-In-Time (JIT) pour les opérations de production.
- Chiffrement en transit : TLS 1.2 minimum avec suites cryptographiques robustes.
- Chiffrement au repos : services de gestion de clés (KMS) avec clés gérées exclusivement par TALBAGO pour les données critiques.
- Réseau : segmentation des environnements, pas d'exposition directe des ports d'administration (SSH, RDP) sur Internet.

Livrable obligatoire — Phase de Conception

• Première version du Plan d'Assurance Sécurité (PAS) incluant les diagrammes d'architecture sécurisée.
• Validation par le RSSI et le CCoE avant démarrage du développement.

6.3. Phase de Développement et d'Implémentation

La phase de réalisation logicielle doit intégrer des garde-fous automatisés. Toute infrastructure doit être définie et déployée exclusivement sous forme de code (Infrastructure as Code — IaC). L'accès en écriture directe aux consoles Cloud pour modifier des environnements de production est proscrit.

La chaîne CI/CD (Continuous Integration / Continuous Deployment) constitue l'épine dorsale de la sécurité opérationnelle et doit intégrer les "Security Gates" suivants :

- SAST (Static Application Security Testing) : analyse statique du code source avant toute fusion dans la branche principale.
- SCA (Software Composition Analysis) : audit des dépendances et bibliothèques open-source (CVE connues, licences).
- IaC Scanning : analyse des templates d'infrastructure avant déploiement (Terraform, CloudFormation).

- DAST (Dynamic Application Security Testing) : tests dynamiques sur environnement de recette avant promotion en production.

6.4. Phase de Recette et de Validation

Avant la mise en production, des tests de sécurité approfondis sont obligatoires. Une revue de sécurité par les pairs (Peer Code Review) avec participation d'un expert sécurité est requise. La réalisation de tests d'intrusion (Penetration Testing) est fortement recommandée.

Conformément aux directives de la norme ISO 27001 (A.8.33), une ségrégation étanche entre les environnements de développement, de test et de production doit être maintenue. L'utilisation de jeux de données synthétiques doit être privilégiée pour la validation fonctionnelle.

6.5. Homologation de Sécurité et Déploiement

La mise en production constitue un transfert de responsabilité et nécessite une validation formelle. L'homologation de sécurité est l'acte par lequel l'Autorité d'Homologation (Direction Générale ou DSI de TALBAGO) atteste de sa pleine connaissance du niveau de sécurité du système et accepte formellement les risques résiduels identifiés, autorisant ainsi sa mise en exploitation.

Immédiatement après le déploiement dans le Cloud public, un outil de Cloud Security Posture Management (CSPM) doit être activé pour surveiller en continu les ressources instanciées et détecter les dérives de configuration (configuration drift).

6.6. Maintien en Condition de Sécurité (MCS) et Fin de Vie

La sécurité d'un projet informatique s'entretient de manière continue tout au long de sa phase d'exploitation. Le Maintien en Condition de Sécurité (MCS) assure que le système reste à jour face à l'évolution des menaces. Cela inclut l'application rigoureuse des correctifs de sécurité (Patch Management) sur les systèmes d'exploitation, middlewares et bibliothèques logicielles.

Lors du retrait de service (fin de vie), la gestion de projet doit englober une phase de démantèlement sécurisé garantissant la restitution ou la destruction irrémédiable des informations sensibles et la révocation systématique de l'ensemble des accès et identités associés.

7. Intégration Transverse : Gestion des Changements et Fournisseurs

7.1. Articulation avec la Politique de Gestion des Changements

Toute modification technique, fonctionnelle ou architecturale apportée à un système en production doit faire l'objet d'une demande formelle de changement. Cette demande déclenche une procédure d'analyse d'impact sécuritaire, évaluant si le changement introduit de nouvelles menaces ou altère les contrôles existants.

Une validation formelle par des pairs ou par le CCoE est requise avant l'implémentation de la modification, assurant la traçabilité et prévenant les incidents liés à des déploiements hasardeux.

7.2. Maîtrise des Risques liés aux Tiers et Fournisseurs Cloud

Le choix de services Cloud ou l'intégration de progiciels tiers introduit un risque externe majeur. La politique de gestion des projets impose que l'évaluation de la sécurité des fournisseurs soit réalisée en amont des phases d'acquisition.

Pour l'hébergement de systèmes d'information sensibles, l'ANSSI recommande fortement de privilégier des fournisseurs de services Cloud qualifiés SecNumCloud, garantissant un très haut niveau d'exigence technique et organisationnelle ainsi qu'une protection juridique contre les lois extraterritoriales (Cloud Act américain).

Lorsque le recours à une offre SecNumCloud n'est pas possible, les clauses contractuelles doivent imposer :

- Des accords de traitement des données (DPA) conformes au RGPD.
- Des exigences de notification d'incidents dans les délais réglementaires.
- Un droit d'audit formel sur les infrastructures du fournisseur.
- Des accords de non-divulgation (NDA) et des connexions d'accès restreintes, tracées et limitées dans le temps.

8. Référentiels et Normes Applicables

Les prestations et mesures définies dans cette politique s'appuient sur les référentiels suivants :

Référentiel	Application dans le cadre de cette politique
ISO/IEC 27001:2022 (A.5.8)	Cadre SMSI — intégration de la sécurité dans la gestion de projet
ISO/IEC 27002:2022	Contrôles de sécurité opérationnels et bonnes pratiques
EBIOS Risk Manager (ANSSI)	Méthode d'analyse de risques applicable à chaque projet
CSA Cloud Controls Matrix (CCM)	Contrôles de sécurité spécifiques aux environnements Cloud
CIS Benchmarks	Configurations de référence pour le durcissement des systèmes
Guide ANSSI — Homologation SI	Processus de validation formelle avant mise en production
Guide ANSSI — SecNumCloud	Qualification des fournisseurs Cloud pour données sensibles
RGPD / Directive NIS2	Obligations réglementaires de protection des données et cybersécurité
NIST SP 800-218 (SSDF)	Secure Software Development Framework — bonnes pratiques DevSecOps

9. Indicateurs de Pilotage (KPIs) et Amélioration Continue

La réussite de cette politique ne peut être garantie sans un dispositif de mesure de la performance objectif et itératif, conformément à l'objectif stratégique OS-4 : "construire une posture de sécurité durable et mesurable". La DSI et le CCoE s'engagent à suivre le tableau de bord d'indicateurs suivant :

Indicateur (KPI)	Objectif opérationnel	Cible de Performance
Couverture des Analyses de Risques	Vérifier l'implication de la cybersécurité dès la phase d'initialisation des projets.	**100 % des projets majeurs**
Adoption de l'Infrastructure as Code (IaC)	Éradiquer les vulnérabilités liées aux erreurs humaines lors du déploiement (score 2,63/5).	**> 95 % des déploiements en production**
Délai de Remédiation des Vulnérabilités Critiques	Mesurer l'agilité des équipes face aux menaces bloquant le pipeline CI/CD.	**< 48 h pour les CVSS > 9,0**

Intégrité des Environnements de Test	Garantir le respect de l'ISO 27001 A.8.33 et prévenir les fuites lors des recettes.	**0 incident critique**
Conformité Post-Déploiement (CSPM)	Vérifier que les environnements de production restent alignés sur les standards CCoE.	**Tendance mensuelle à la baisse**
Taux d'Homologation de Sécurité	Confirmer l'acceptation formelle des risques résiduels avant exposition des services.	**100 % des applications exposées**

L'analyse périodique de ces indicateurs alimente le processus d'amélioration continue du Système de Management de la Sécurité de l'Information (SMSI) de TALBAGO. En cas d'écarts significatifs ou persistants, le CCoE a pour mission de réviser les standards, d'adapter l'outillage fourni aux équipes, ou de déclencher des programmes de formation ciblés.

10. Procédure d'Évolution et de Révision

La présente politique est soumise à révision annuelle ou lors de tout événement déclencheur significatif :

- Évolution majeure du périmètre Cloud ou des architectures de TALBAGO.
- Modification substantielle du cadre réglementaire applicable (RGPD, NIS2, DORA).
- Survenance d'un incident de sécurité majeur révélant une lacune dans le dispositif.
- Résultat d'audit interne ou externe identifiant des non-conformités significatives.

Toute modification du document est soumise à validation par le RSSI et approuvée par la Direction Générale avant diffusion aux parties prenantes concernées.

11. Sanctions et Non-Conformité

Le non-respect des obligations définies dans la présente politique peut entraîner des mesures disciplinaires internes, conformément au règlement intérieur de TALBAGO et aux dispositions contractuelles applicables aux prestataires.

Sur le plan contractuel, les pénalités prévues dans le Cahier des Clauses Administratives Particulières (CCAP) du marché TALBAGO-DSI-SEC-CLOUD-2026-01 s'appliquent en cas de manquement aux obligations de sécurité par les titulaires de marchés.

Sur le plan réglementaire, le non-respect des obligations du RGPD expose TALBAGO à des sanctions pouvant atteindre 4 % du chiffre d'affaires annuel mondial ou 20 millions d'euros (le montant le plus élevé étant retenu). Les manquements aux obligations NIS2 peuvent entraîner des sanctions administratives équivalentes.

PARTIE II — PROCÉDURE DE GESTION DES PROJETS CYBERSÉCURITÉ

À propos de ce document

La présente procédure est le complément opérationnel de la Politique (Partie I). Elle précise les étapes, acteurs, livrables obligatoires et critères de validation à respecter pour chaque phase du cycle de vie SecSDLC. Elle s'applique à tout projet relevant du périmètre défini à l'article 1.2 de la Politique.
Référence procédure : TALBAGO-PROC-CSPM-2026-01 | Version 1.0 | Mars 2026

PRO-1. Phase d'Initialisation — Qualification Sécurité du Projet

Toute nouvelle initiative informatique doit faire l'objet d'une qualification de sécurité préalable avant l'allocation de ressources. Cette phase détermine le niveau d'exigences de sécurité applicable à l'ensemble du cycle de vie.

Étape PRO-1.1 — Déclenchement et Qualification

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Chef de Projet • RSSI • Équipe métier	• Renseigner la fiche projet (PRO-FORM-001) • Identifier les actifs et données concernés • Qualifier la sensibilité (public / interne / confidentiel / données perso RGPD) • Déterminer la criticité du service métier supporté	• Expression du besoin métier • Catalogue des actifs TALBAGO • Politique de classification des données	• Fiche de qualification projet signée • Classification initiale des actifs • Niveau de criticité DICT (Dispo, Intégrité, Conf., Traçabilité)

✓ **Critère Go/No-Go :** La fiche de qualification est validée par le RSSI avant démarrage de l'analyse de risques.

Étape PRO-1.2 — Analyse de Risques EBIOS Risk Manager

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Chef de Projet • RSSI • Architecte Cloud • CCoE	• Identifier les scénarios de menaces pertinents • Évaluer la vraisemblance et la gravité des impacts • Définir les mesures de sécurité proportionnées • Constituer le registre des risques du projet	• Fiche de qualification projet • Résultats évaluation de maturité TALBAGO (score 3,01/5) • Méthode EBIOS Risk Manager (ANSSI)	• Registre des risques du projet v1.0 • Exigences de sécurité DICT définies • Mesures de sécurité priorisées

✓ **Critère Go/No-Go :** Le registre des risques est validé par le RSSI. Sans validation, aucune phase de conception ne peut démarrer.

Étape PRO-1.3 — Analyse d'Impact sur la Protection des Données (AIPD)

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Chef de Projet • DPO / RSSI • Équipe développement	• Vérifier si le projet traite des données à caractère personnel • Réaliser l'AIPD si seuil RGPD atteint	• Fiche de qualification projet • Registre des traitements TALBAGO • Lignes directrices CNIL sur l'AIPD	• AIPD validée (si applicable) • Liste des traitements ajoutée au registre TALBAGO

	• Documenter les mécanismes Privacy by Design • Définir durées de conservation et mesures de minimisation		• Clauses DPA pour les prestataires impliqués

✓ **Critère Go/No-Go :** Si le projet traite des données personnelles sensibles, l'AIPD est obligatoire et doit être approuvée avant démarrage. En l'absence d'AIPD, le projet est suspendu.

Livrables obligatoires — Phase d'Initialisation (PRO-1)

☐ PRO-FORM-001 : Fiche de qualification projet (signée RSSI)
☐ Registre des risques EBIOS RM v1.0 (validé RSSI + CCoE)
☐ AIPD si données personnelles (approuvée DPO/RSSI)
☐ Classification des actifs et des données du projet
☐ Exigences de sécurité DICT formalisées

PRO-2. Phase de Conception — Architecture Sécurisée

Étape PRO-2.1 — Conception Architecture Zero Trust

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Architecte Cloud & Sécurité • RSSI • CCoE	• Appliquer le principe Zero Trust à toute l'architecture • Définir la segmentation réseau (VPC, sous-réseaux, security groups) • Interdire toute exposition directe SSH/RDP/bases de données sur Internet • Spécifier les flux de communication autorisés (whitelist)	• Registre des risques v1.0 • Exigences de sécurité DICT • Référentiels CIS Benchmarks / ANSSI Cloud	• Diagramme d'architecture sécurisée v1 • Matrice des flux autorisés • Spécification des règles de segmentation réseau

✓ **Critère Go/No-Go :** L'architecture Zero Trust est validée par le RSSI et le CCoE avant démarrage du développement.

Étape PRO-2.2 — Spécification IAM et Gestion des Accès

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Architecte Cloud • Équipes IAM • RSSI	• Définir les rôles et politiques IAM selon le principe du moindre privilège • Imposer le MFA sur tous les vecteurs (console, CLI, API) • Configurer le SSO fédéré comme unique mécanisme d'accès console • Définir les mécanismes JIT pour les accès de production • Planifier la rotation des clés et secrets	• Architecture réseau validée • Catalogue des rôles et responsabilités projet • Politique IAM TALBAGO	• Politiques IAM documentées • Matrice des droits d'accès par environnement • Procédure de gestion des accès JIT

✓ **Critère Go/No-Go :** Les politiques IAM sont revues par le RSSI. L'absence de MFA sur un vecteur d'accès est un critère No-Go bloquant.

Étape PRO-2.3 — Spécification du Chiffrement et Protection des Données			
Acteurs • Architecte Cloud • RSSI • Équipes développement	**Actions principales** • Définir le chiffrement en transit : TLS 1.2 minimum (TLS 1.3 recommandé) • Définir le chiffrement au repos : KMS avec clés maîtrisées par TALBAGO pour données critiques • Interdire l'usage de clés gérées par le fournisseur Cloud pour les données sensibles • Planifier la rotation régulière des clés de chiffrement • Spécifier la gestion des secrets (coffre-fort secret)	**Entrées / Prérequis** • Classification des données du projet • Politique de protection des données TALBAGO • Exigences RGPD / NIS2	**Sorties / Livrables** • Spécification de chiffrement validée • Plan de gestion des clés KMS • Configuration du coffre-fort de secrets
✓ **Critère Go/No-Go :** Toute donnée classifiée confidentielle ou personnelle doit bénéficier d'un chiffrement au repos avec clé KMS maîtrisée par TALBAGO. Non-respect = No-Go.			

Étape PRO-2.4 — Élaboration du Plan d'Assurance Sécurité (PAS) Initial			
Acteurs • Chef de Projet • RSSI • Prestataire Cybersécurité	**Actions principales** • Rédiger la première version du PAS couvrant tous les aspects de sécurité • Inclure : inventaire actifs, mesures techniques/organisationnelles/physiques • Documenter les procédures de gestion des incidents • Formaliser les engagements de conformité RGPD / NIS2 • Soumettre le PAS à l'approbation de TALBAGO	**Entrées / Prérequis** • Registre des risques • Architecture sécurisée • Politiques IAM et chiffrement • Exigences contractuelles CCTP / CCAP	**Sorties / Livrables** • PAS v1.0 soumis pour approbation • Matrice de couverture des exigences de sécurité • Planning prévisionnel de sécurité
✓ **Critère Go/No-Go :** Le PAS doit être approuvé par TALBAGO dans un délai de 15 jours après notification du marché. Sans approbation du PAS, le démarrage des développements est bloqué.			

Livrables obligatoires — Phase de Conception (PRO-2)

☐ Diagramme d'architecture sécurisée Zero Trust (validé RSSI + CCoE)
☐ Politiques IAM documentées avec matrice des droits d'accès
☐ Spécification de chiffrement (transit + repos + gestion des clés KMS)
☐ PAS v1.0 approuvé par TALBAGO
☐ Registre des risques mis à jour v1.1

PRO-3. Phase de Développement — DevSecOps et Infrastructure as Code

Étape PRO-3.1 — Mise en Place des Security Gates CI/CD			
Acteurs • Équipes DevOps • Architecte Cloud • CCoE	**Actions principales** • Configurer le pipeline CI/CD avec les étapes de sécurité obligatoires	**Entrées / Prérequis** • Architecture CI/CD de l'équipe • Outils SAST/SCA approuvés par le CCoE	**Sorties / Livrables** • Pipeline CI/CD sécurisé documenté • Configuration des Security Gates

	• Intégrer SAST : analyse statique du code source (ex : SonarQube, Semgrep) • Intégrer SCA : audit des dépendances open-source (ex : Snyk, Dependabot) • Configurer l'IaC Scanning : analyse des templates Terraform/CloudFormation (ex : Checkov, tfsec) • Définir les seuils de blocage (CVSS ≥ 7,0 = warning / CVSS ≥ 9,0 = blocage automatique)	• Politique de gestion des vulnérabilités TALBAGO	• Seuils de blocage formalisés et activés

✓ **Critère Go/No-Go :** Le pipeline CI/CD doit être opérationnel avec au minimum SAST et SCA avant tout premier déploiement. Tout pipeline sans Security Gates est bloqué.

Étape PRO-3.2 — Déploiement Infrastructure as Code (IaC)

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Équipes DevOps • Architecte Cloud	• Définir 100 % de l'infrastructure en IaC (Terraform, CloudFormation, Bicep) • Versionner les scripts IaC dans un dépôt Git sécurisé • Soumettre tout changement IaC au Security Gate d'IaC Scanning • Interdire formellement les modifications manuelles via la console Cloud en production • Documenter les configurations et paramètres de déploiement	• Architecture sécurisée validée • Templates IaC des composants approuvés CCoE • Référentiels CIS Benchmarks pour configurations Cloud	• Code IaC versionné et documenté • Configurations de déploiement validées • Rapports IaC Scanning sans vulnérabilité critique

✓ **Critère Go/No-Go :** Toute ressource Cloud en production déployée manuellement (hors IaC) est un écart critique. L'équipe CCoE doit être notifiée dans l'heure. Suppression ou correction sous 24 h.

Étape PRO-3.3 — Gestion des Secrets et Rotation des Clés

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Équipes DevOps • Équipes IAM • Architecte Cloud	• Interdire la présence de secrets (mots de passe, clés API, certificats) en clair dans le code • Configurer un coffre-fort de secrets (ex : HashiCorp Vault, AWS Secrets Manager, Azure Key Vault) • Automatiser la rotation des clés de chiffrement et des secrets d'accès • Mettre en place la détection de secrets exposés dans le code (ex : GitGuardian, truffleHog) • Former les développeurs aux bonnes pratiques de gestion des secrets	• PAS approuvé • Architecture KMS validée • Politique de rotation des clés	• Coffre-fort de secrets configuré • Politique de rotation des clés activée • Outil de détection de secrets en place dans le pipeline

✓ **Critère Go/No-Go :** La détection de secrets exposés dans le dépôt de code est obligatoire. Tout secret détecté en clair déclenche un blocage immédiat du pipeline et une notification au RSSI sous 30 minutes.

Livrables obligatoires — Phase de Développement (PRO-3)

☐ Pipeline CI/CD documenté avec Security Gates activés (SAST + SCA + IaC Scanning)
☐ Code IaC versionné dans Git, avec rapports de scanning sans critique
☐ Coffre-fort de secrets configuré et politique de rotation des clés activée
☐ Rapport de conformité CIS Benchmarks sur les configurations Cloud
☐ Registre des risques mis à jour v1.2

PRO-4. Phase de Recette — Validation Sécurité

Étape PRO-4.1 — Tests Dynamiques (DAST) et Revue de Sécurité

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Équipes DevOps • RSSI • Expert Sécurité	• Déployer l'application sur l'environnement de recette (isolé de la production) • Exécuter les tests dynamiques DAST (ex : OWASP ZAP, Burp Suite) • Réaliser une revue de sécurité du code par les pairs avec participation d'un expert sécurité • Analyser les résultats et prioriser les vulnérabilités selon leur criticité (CVSS) • Traiter les vulnérabilités critiques et élevées avant toute promotion en production	• Application déployée sur environnement de recette isolé • Pipeline CI/CD validé phases précédentes • Plan de tests de sécurité approuvé RSSI	• Rapport DAST complet • Rapport de revue de code sécurité • Plan de remédiation priorisé

✓ **Critère Go/No-Go :** Toute vulnérabilité critique (CVSS ≥ 9,0) identifiée en DAST est un No-Go bloquant. La promotion en production est impossible avant remédiation et re-test confirmant la correction.

Étape PRO-4.2 — Tests d'Intrusion (Penetration Testing)

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Prestataire sécurité mandaté • RSSI • Chef de Projet	• Définir le périmètre et les règles d'engagement du pentest • Réaliser le test d'intrusion (boîte noire ou boîte grise selon criticité) • Analyser les résultats et produire le rapport de pentest • Définir et suivre le plan de remédiation • Réaliser un test de contre-mesure si des vulnérabilités critiques ont été identifiées	• Application déployée sur environnement de recette • Résultats DAST disponibles • Cahier des charges du pentest	• Rapport de test d'intrusion • Plan de remédiation signé • Attestation de contre-mesure si applicable

✓ **Critère Go/No-Go :** Le test d'intrusion est fortement recommandé pour les projets Cloud exposés à Internet. Il est obligatoire pour les applications traitant des données sensibles ou personnelles.

Étape PRO-4.3 — Validation du PAS Définitif et Dossier d'Homologation

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Chef de Projet • RSSI • CCoE	• Mettre à jour le PAS avec tous les résultats de tests de sécurité • Consolider le dossier d'homologation (architecture, tests, rapports, plan d'action) • Documenter les risques résiduels et les mesures de compensation • Soumettre le dossier à l'Autorité d'Homologation (DSI / Direction) • Obtenir la décision formelle d'homologation avant tout déploiement en production	• Rapports DAST et pentest • Registre des risques mis à jour • Architecture et PAS finaux	• PAS définitif approuvé • Dossier d'homologation complet • Décision formelle d'homologation signée • Liste des risques résiduels acceptés

✓ **Critère Go/No-Go :** La décision d'homologation est obligatoire et doit être signée par l'Autorité d'Homologation avant tout déploiement en production. Aucune exception n'est autorisée.

Livrables obligatoires — Phase de Recette (PRO-4)

☐ Rapport DAST sans vulnérabilité critique non traitée
☐ Rapport de test d'intrusion (si applicable) et plan de remédiation
☐ PAS définitif v2.0 approuvé par TALBAGO
☐ Dossier d'homologation complet soumis à l'Autorité d'Homologation
☐ Décision formelle d'homologation signée

PRO-5. Déploiement en Production et Activation des Contrôles

Étape PRO-5.1 — Déploiement Sécurisé et Activation CSPM

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Équipes DevOps • Architecte Cloud • CCoE	• Déployer via pipeline CI/CD (zéro intervention manuelle) • Activer l'outil de Cloud Security Posture Management (CSPM) • Configurer les règles de conformité CCoE dans le CSPM • Vérifier l'alignement de la configuration déployée avec l'architecture validée • Activer les alertes de dérive de configuration (Configuration Drift)	• Décision d'homologation signée • Pipeline CI/CD validé • Règles de conformité CCoE définies	• Rapport de déploiement • CSPM activé et configuré • Alertes de drift opérationnelles • Configuration post-déploiement validée

✓ **Critère Go/No-Go :** Le CSPM doit être activé et opérationnel dans les 4 heures suivant tout déploiement en production. Aucune exception n'est tolérée.

Étape PRO-5.2 — Intégration Supervision et Journalisation SOC

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Équipes DevOps • Équipes SOC • Architecte Cloud	• Vérifier que les journaux d'événements sont bien collectés (authentifications,	• Architecture de journalisation définie en phase de conception	• Logs intégrés dans le SIEM

	modifications de droits, transactions sensibles) • Intégrer les flux de logs dans le SIEM / SOC de TALBAGO • Définir les règles de détection et alertes pour les événements de sécurité critiques • Tester les capacités de détection sur un incident simulé • Documenter les runbooks de réponse aux incidents Cloud	• Accès au SIEM TALBAGO • Politique de supervision de sécurité	• Règles de détection actives • Runbooks de réponse aux incidents documentés • Test de détection réalisé et validé
✓ **Critère Go/No-Go :** L'intégration des logs dans le SOC/SIEM est obligatoire avant mise en service opérationnel. Tout système non supervisé est considéré comme non conforme.			

Livrables obligatoires — Déploiement (PRO-5)

☐ Rapport de déploiement IaC signé (Chef de Projet + Architecte Cloud)
☐ CSPM activé avec règles CCoE et alertes de drift opérationnelles
☐ Logs intégrés dans le SOC/SIEM et règles de détection testées
☐ Runbooks de réponse aux incidents Cloud documentés
☐ Notification aux équipes métier de la mise en service

PRO-6. Maintien en Condition de Sécurité (MCS)

Étape PRO-6.1 — Patch Management et Veille Vulnérabilités

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Équipes DevOps • Architecte Cloud • RSSI	• Suivre les bulletins de sécurité des composants utilisés (OS, middlewares, bibliothèques) • Évaluer et prioriser les correctifs selon la criticité (CVSS) • Appliquer les correctifs critiques (CVSS ≥ 9,0) sous 48 heures • Appliquer les correctifs élevés (CVSS ≥ 7,0) sous 7 jours • Mettre à jour régulièrement les images de base des conteneurs et VMs • Documenter toutes les interventions dans le journal de maintenance	• CSPM en production • Flux CVE (NVD, CERT-FR, ANSSI) • Inventaire des composants logiciels (SBOM)	• Journal de patch management à jour • Rapports de conformité mensuel • Tableau de bord des vulnérabilités ouvertes
✓ **Critère Go/No-Go :** Les délais de remédiation sont des engagements contractuels (KPI-03). Tout dépassement sur une vulnérabilité critique doit être escaladé au RSSI dans l'heure.			

Étape PRO-6.2 — Revue Périodique des Accès et Droits IAM

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Équipes IAM		• Registre des accès IAM	

• RSSI • Responsables métiers	• Réaliser une revue trimestrielle de l'ensemble des droits d'accès en production • Vérifier l'application du principe de moindre privilège • Révoquer immédiatement les accès non nécessaires ou appartenant à des personnes ayant quitté le projet • Auditer les comptes de service et clés API inactifs • Documenter les résultats dans le registre des révisions d'accès	• Annuaire des collaborateurs TALBAGO • Politique de gestion des accès	• Rapport de revue des accès trimestriel • Liste des accès révoqués • Tableau de bord IAM mis à jour

✓ **Critère Go/No-Go :** La revue trimestrielle des accès est obligatoire. Tout accès non-justifié découvert lors d'une révision doit être révoqué immédiatement sans délai de grâce.

PRO-7. Fin de Vie — Démantèlement Sécurisé

Étape PRO-7.1 — Procédure de Démantèlement

Acteurs	Actions principales	Entrées / Prérequis	Sorties / Livrables
• Chef de Projet • Architecte Cloud • RSSI • Responsable métier	• Notifier formellement toutes les parties prenantes du retrait de service • Révoquer systématiquement l'ensemble des accès et identités associés au système • Supprimer ou anonymiser de façon irrémédiable les données selon leur classification • Décommissionner les ressources Cloud (instances, stockage, réseaux) via IaC • Conserver les journaux d'audit conformément aux obligations légales (durées de conservation RGPD) • Produire le rapport de fin de mission	• Décision formelle de retrait de service • Inventaire complet des accès et ressources Cloud • Politique de destruction des données TALBAGO	• Rapport de démantèlement sécurisé signé • Attestation de révocation de tous les accès • Attestation de destruction ou archivage conforme des données • Rapport de fin de mission

✓ **Critère Go/No-Go :** Le rapport de démantèlement sécurisé doit être signé par le Chef de Projet ET le RSSI avant clôture administrative du projet. Aucune ressource Cloud orpheline n'est tolérée.

Livrables obligatoires — Fin de Vie (PRO-7)

☐ Décision formelle de retrait de service
☐ Attestation de révocation de tous les accès (comptes utilisateurs, comptes de service, clés API)
☐ Attestation de destruction/archivage conforme des données (conforme RGPD)
☐ Confirmation de décommissionnement de toutes les ressources Cloud
☐ Rapport de démantèlement sécurisé signé (Chef de Projet + RSSI)

PRO-8. Gestion des Dérogations

Lorsqu'une équipe n'est pas en mesure de respecter une obligation de la présente procédure, une demande de dérogation formelle doit être soumise. Aucune dérogation implicite ou verbale n'est acceptée.

Réf.	Document	Initiateur	Approbateur	Délai	Statut
DER-FORM-001	Formulaire de demande de dérogation	Chef de Projet	RSSI + CCoE	48 h max	Applicable
DER-FORM-002	Registre des dérogations accordées	CCoE	DSI	Continue	Applicable
DER-FORM-003	Plan de compensation sécuritaire	Chef de Projet	RSSI	Selon criticité	Obligatoire si dérogation accordée

La dérogation est accordée uniquement si un plan de compensation sécuritaire équivalent est proposé et approuvé. L'acceptation d'une dérogation ne décharge pas l'équipe de sa responsabilité de sécurité. Le CCoE assure le suivi de l'application des mesures compensatoires.

PRO-9. Procédure d'Escalade et de Gestion des Incidents Sécurité

Tout incident ou événement de sécurité survenant au cours d'un projet doit être traité selon les délais et modalités définis ci-dessous :

Événement déclencheur	Délai max	Détecteur	Destinataire	Action requise
Vulnérabilité critique (CVSS ≥ 9,0) détectée en CI/CD	< 30 min	Chef de Projet	RSSI + CCoE	Blocage pipeline CI/CD, analyse immédiate, plan de remédiation sous 48 h
Incident de sécurité en environnement de recette	< 1 h	Chef de Projet	RSSI	Isolation de l'environnement, analyse forensique, notification conformité RGPD si données perso
Dérive de configuration (CSPM) en production	< 4 h	Architecte Cloud	CCoE + RSSI	Correction automatisée ou manuelle, rapport d'incident, revue des IaC
Non-conformité réglementaire identifiée (RGPD/NIS2)	< 24 h	RSSI	DSI + Direction	Activation cellule conformité, notification CNIL si violation données (72 h max)
Dépassement de délai d'homologation	< 48 h	Chef de Projet	DSI	Évaluation risque résiduel, décision Go/No-Go par l'Autorité d'Homologation

En cas d'incident de sécurité confirmé, le prestataire CYBERSECURITÉ FRANCE applique le processus en 7 étapes défini dans le PAS : Détection → Qualification → Notification TALBAGO/RSSI → Analyse → Confinement → Remédiation → Retour d'expérience.

PRO-10. Formulaires et Documents de Référence

Référence	Document
PRO-FORM-001	Fiche de qualification et lancement de projet sécurisé
PRO-FORM-002	Registre des risques EBIOS RM (template)
PRO-FORM-003	Template AIPD (Analyse d'Impact sur la Protection des Données)
PRO-FORM-004	Checklist Security Gates CI/CD
PRO-FORM-005	Template Plan d'Assurance Sécurité (PAS)
PRO-FORM-006	Dossier de recette sécurité (DAST + pentest)
PRO-FORM-007	Dossier d'homologation de sécurité (ANSSI-conforme)
PRO-FORM-008	Rapport de déploiement et activation CSPM
PRO-FORM-009	Rapport de revue trimestrielle des accès IAM
PRO-FORM-010	Rapport de démantèlement sécurisé
PRO-FORM-011	Formulaire de demande de dérogation (DER-FORM-001)
PRO-FORM-012	Journal de patch management

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite.